

---

WHITE PAPER · AI OPERATING GOVERNANCE

# Choose AI Limits Before the Model

Set the permitted use, data, and actions before a vendor choice makes them harder to change

---

**Marco Policani**

Enterprise Portfolio · PMO · AI Operating Governance

[policani.net](http://policani.net) · [linkedin.com/in/marcpolicani](https://linkedin.com/in/marcpolicani)

August 2026

## EXECUTIVE SUMMARY

**Set the use, data, and action limits before comparing vendors. Then choose a model that fits.**

A strong AI demo can make a vendor choice feel settled before anyone agrees on its permitted use, data, or actions. Set those limits first, then compare models that fit.

- 01** Before comparing vendors, write five things on one page: the permitted use, the data allowed, the strongest action the tool may take, who owns each part of the work, and what sends the decision back for review.
- 02** Make two passes: set those limits before the shortlist, then test the chosen model, hosting, and contract against them before committing.
- 03** If the chosen option needs broader data access or a stronger action than the limits allow, make that a visible new decision so procurement cannot change the use by accident.

---

## The demo answers the wrong question

A strong model demo can make a choice feel settled. The team starts comparing quality, speed, and price. Later, someone asks where the data will go, which people the tool can affect, and whether it can act without a person approving it. By then, a preferred vendor may have sponsors, and a new limit can sound like resistance.

Start somewhere else. Before comparing models, state the work the tool may support, the data it may use, and the strongest action it may take. Name who can approve a change. Then ask which candidates fit those limits.

The European Commission's AI Act page, on rules for AI used in the EU, shows why a single date or vendor label is not enough. Some rules took effect before the general August 2, 2026 milestone, and some high-risk requirements start later.[1] The operating team does not decide the legal conclusion. It gives legal and compliance owners a clear description of the planned use.

## Write the facts before the shortlist

The EU AI Act uses the intended purpose, the organization's role, and the context of use when it assigns duties.[2] The same practical facts help any organization make a sound choice: who uses the tool, who can be affected, what it does, where it runs, and what happens when it is wrong.

Keep the description short enough to use. "An enterprise assistant" is not a workable description. A workable one reads: "Drafts internal service replies for one support group, using approved articles, with a person sending every reply." It tells reviewers what to test and what would require a new decision.

Dates and rules can change. The EU's 2026 Digital Omnibus moved some high-risk requirements to 2027 or 2028 and set a transition for some transparency duties.[3] That makes a durable record more useful than a yes-or-no compliance field. The record should keep the facts that counsel, security, procurement, and business owners need to revisit.

---

## Make five decisions

### 1. Set the use

Name the process, users, people affected, locations, expected result, and what stays out of scope. A small internal draft tool can have a light review. A tool that ranks applicants, handles regulated records, or starts payments needs more.

## EXHIBIT 1

**Five choices define an AI deployment**

- ① **Use**  
Name the process, users, affected people, and exclusions.
- ② **Data**  
List permitted and prohibited data and how it moves.
- ③ **Action**  
Set the strongest permitted action and name the decision that remains human.
- ④ **Work split**  
Name owners for evidence, changes, incidents, and exit.
- ⑤ **Review**  
Set approvers and changes that send the case back.

**2. Set the data**

List permitted and prohibited data. Include the source, movement, retention, training use, access, deletion, and any vendor or region limit. A data rule that exists only in a slide deck may not stop an integration from changing it.

**3. Set the action limit**

State the strongest thing the tool may do: retrieve, draft, recommend, or act. Name the human decision it cannot make. The NIST AI Risk Management Framework starts with intended use, context, documented risk tolerance, roles, and third-party risks.[4] [5] Those topics make a model comparison useful instead of generic.

**4. Split the work**

Name who owns the business result, technical setup, data approval, security review, contract terms, incidents, and exit. Cloud security guidance describes a shared responsibility model; the provider and customer each own part of the work.[6][7] Write down the split for the actual service instead of depending on a slogan.

**5. Set approval and review triggers**

Name who approves the first version, who approves the selected candidate, and what sends the decision back for review. New users, a new region, a different data class, an outside integration, or an automated action can all change the original case.

---

## Use two passes

The first pass happens before the shortlist. It sets the intended use, excluded uses, allowed data, maximum action, owner, and firm limits. Teams do not need every technical answer yet. They do need enough to stop wasting time on options they cannot use.

### EXHIBIT 2

#### Three points keep the limits visible

- ① **Before shortlist**  
Set the use, data, action, owner, and firm limits.
- ② **Before commitment**  
Test the selected model, hosting, contract, and workflow.
- ③ **When it changes**  
Return broader data or stronger actions for a new decision.

The second pass happens before commitment. Test the chosen model, hosting, contract, supplier chain, and workflow against the first record. The NIST Generative AI Profile covers design, development, use, and evaluation across the lifecycle.[8] It is a useful reminder that a model choice is not only a model choice.

If the candidate requires broader data access or a stronger action, make that change visible. The sponsor may still approve it, but procurement cannot change the use by accident.

---

## Keep one record

For each of the five decisions, record the evidence, owner, date, and status: fact, judgment, or open question. An open question is not a failure if someone owns it and it has a due date before the related commitment.

Keep rejected options too. A local tool, managed service, smaller model, non-AI change, or decision to wait may fit the limits better. NIST's AI RMF Core and Playbook point organizations to context, alternatives, and third-party risks.[5][9] Keeping rejected options prevents the selected tool from being remembered as inevitable.

---

## What to do next

Take one AI request that is about to enter sourcing. Write the use, data, action limit, work split, and review triggers on one page. Give each open item an owner and date. Only then compare the models that fit.

---

### EXHIBIT 3

Write the five limits before comparing vendors.

---

## Notes and sources

[1] European Commission, AI Act, Shaping Europe's digital future, updated August 3, 2026.

[2] European Parliament and Council of the European Union, Regulation (EU) 2024/1689 of 13 June 2024 laying down harmonised rules on artificial intelligence, Official Journal of the European Union, July 12, 2024.

[3] European Parliament and Council of the European Union, Regulation (EU) 2026/1744 of 8 July 2026 amending Regulations (EU) 2024/1689, (EU) 2018/1139 and (EU) 2023/1230 as regards the simplification of the implementation of harmonised rules on artificial intelligence (Digital Omnibus on AI), Official Journal of the European Union, July 24, 2026.

[4] Elham Tabassi, Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1, National Institute of Standards and Technology, January 26, 2023.

[5] National Institute of Standards and Technology, AI RMF Core, Artificial Intelligence Resource Center, excerpt from Artificial Intelligence Risk Management Framework (AI RMF 1.0), January 2023.

[6] Cybersecurity and Infrastructure Security Agency, United States Digital Service, and Federal Risk and Authorization Management Program, Cloud Security Technical Reference Architecture, Version 2.0, June 2022.

[7] Wayne Jansen and Timothy Grance, Guidelines on Security and Privacy in Public Cloud Computing, NIST Special Publication 800-144, National Institute of Standards and Technology, December 2011.

[8] Chloe Autio, Reva Schwartz, Jesse Dunietz, Shomik Jain, Martin Stanley, Elham Tabassi, Patrick Hall, and Kamie Roberts, Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, National Institute of Standards and Technology, July 26, 2024.

[9] National Institute of Standards and Technology, AI RMF Playbook, Map function, Artificial Intelligence Resource Center, companion to the Artificial Intelligence Risk Management Framework (AI RMF 1.0), accessed October 8, 2026.

### About the author

Marco Policani is an enterprise portfolio, PMO, and AI operating-governance leader. He builds portfolio governance systems where AI carries the analytical load and named humans own every decision — an approach documented across case studies, walkthroughs, and working governance guides on his portfolio site.

Portfolio & governance library: [policani.net/governance](https://policani.net/governance) · Full portfolio: [policani.net](https://policani.net) · LinkedIn: [linkedin.com/in/marcpolicani](https://linkedin.com/in/marcpolicani)

This white paper may be shared freely with attribution. © 2026 Marco Policani.